Your cyber security baseline

A guided conversation through the No Fries questionnaire



14 questions. One shared starting point.

The scope of this assessment

We agree what the answers cover before we begin.

THE DECLARATION

Organisation and date
Systems, services and important data
Business-critical and internet-facing systems
Relevant providers and exclusions

EXAMPLE SCOPE

“Our New Zealand office, staff laptops, Microsoft 365, finance system, website and supporting IT provider.”

An honest answer is useful

Choose the answer that reflects the agreed scope today.

Yes	The practice operates across the scope.
Partial	Some parts operate. Coverage or process has gaps.
No	The practice is absent.
Unknown	We need to check before we can answer.
Not applicable	Explain why it does not apply. The claim needs review.

NF-NCSC-MCSS-RM-01-Q1

Guide and Govern

Are cyber risks managed through a documented business risk process with tolerance, owners and regular review?

WHAT THIS MEANS

Cyber risks belong in the business risk process. Each needs an owner, an agreed tolerance and a review date.

WHY IT MATTERS

Leaders can decide which risks to reduce, fund or accept.

EXAMPLE ANSWER: PARTIAL

“We have a cyber risk register and owners. Leadership reviews it informally, but we haven’t agreed our tolerance.”

EVIDENCE TO DISCUSS

Current cyber risk register
Governance review minutes

NF-NCSC-MCSS-SA-01-Q1

Guide and Govern

Do people receive current, role-appropriate security guidance from onboarding onward, with results reported to leadership?

WHAT THIS MEANS

People get useful security guidance when they join and as their role changes. Leaders can see participation and results.

WHY IT MATTERS

People need to recognise suspicious requests and know how to report them.

EXAMPLE ANSWER: PARTIAL

“New starters get security guidance. We haven’t refreshed it for existing staff or reported exercise results to leadership.”

EVIDENCE TO DISCUSS

Completion records
Phishing or reporting exercise results

NF-NCSC-MCSS-AI-01-Q1

Identify and Understand

Is there a current inventory of important hardware, software, cloud services and data with owners and lifecycle status?

WHAT THIS MEANS

One current list identifies important devices, software, cloud services and data, including who owns them and support dates.

WHY IT MATTERS

You can protect and replace important systems only when you know they exist.

EXAMPLE ANSWER: PARTIAL

“Our laptop list is current. We still need to add cloud services, important data owners and end-of-support dates.”

EVIDENCE TO DISCUSS

Hardware and software inventory
Cloud and SaaS register

NF-NCSC-MCSS-SC-01-Q1

Prevent and Protect

Are secure configuration baselines applied to new and existing systems, with exceptions reviewed when software changes?

WHAT THIS MEANS

Systems use agreed secure settings. The team checks changes and keeps a record of exceptions.

WHY IT MATTERS

Default settings and unnoticed changes can create avoidable exposure.

EXAMPLE ANSWER: PARTIAL

“We apply a standard setup to new laptops. Older devices and cloud settings haven’t had the same review.”

EVIDENCE TO DISCUSS

Device or tenant policy export
Configuration review record

NF-NCSC-MCSS-PA-01-Q1

Prevent and Protect

Are patches prioritised, sourced, tested, deployed and verified through a repeatable process that includes rollback and retirement?

WHAT THIS MEANS

Patches follow a repeatable process, with priorities, checks, a way to undo problems and a plan for unsupported systems.

WHY IT MATTERS

A patch needs to reach the right systems and work after installation.

EXAMPLE ANSWER: PARTIAL

“Laptops update automatically. We don’t yet verify third-party applications, firmware or overdue exceptions.”

EVIDENCE TO DISCUSS

Patch compliance export
Exception register

NF-NCSC-MCSS-MF-01-Q1

Prevent and Protect

Is MFA enforced for critical, internet-accessible, privileged and relevant third-party access, with failures reviewed?

WHAT THIS MEANS

Multi-factor authentication applies to important access, including administrators and relevant suppliers. The team reviews failures and exclusions.

WHY IT MATTERS

A stolen password should be harder to turn into access to important systems.

EXAMPLE ANSWER: PARTIAL

“Email and remote access require MFA. We still need to check administrator accounts, finance services and supplier access.”

EVIDENCE TO DISCUSS

MFA coverage report
Failed-authentication review

NF-NCSC-MCSS-DU-01-Q1

Detect and Contain

Are useful logs from critical and externally facing systems brought together, reviewed and turned into actionable alerts?

WHAT THIS MEANS

Important systems send useful activity records to a place where someone reviews alerts and responds.

WHY IT MATTERS

An alert helps only when someone can investigate it and act in time.

EXAMPLE ANSWER: UNKNOWN

“Our provider handles monitoring. We haven’t confirmed which systems send logs or who responds after hours.”

EVIDENCE TO DISCUSS

Central logging coverage
Alert-to-ticket and response samples

NF-NCSC-MCSS-LP-01-Q1

Prevent and Protect

Is access limited to what each person needs, with separate privileged accounts and repeatable joiner, mover, leaver and review processes?

WHAT THIS MEANS

People receive only the access they need. Administrator access stays separate, and access changes when people join, move or leave.

WHY IT MATTERS

Limited access reduces accidental changes and the reach of a compromised account.

EXAMPLE ANSWER: PARTIAL

“Leavers lose access promptly. Some staff still use administrator accounts for daily work, and reviews are irregular.”

EVIDENCE TO DISCUSS

Access review
Joiner-mover-leaver records

NF-NCSC-MCSS-DR-01-Q1

Respond and Recover

Are critical systems and data backed up to defined recovery requirements, with protected copies and sampled restore tests?

WHAT THIS MEANS

Backups cover important data and systems. Protected copies and restore tests show whether recovery can meet business needs.

WHY IT MATTERS

A successful backup job does not establish that the business can recover.

EXAMPLE ANSWER: PARTIAL

“Backups run every night. We haven’t recently restored a sample or checked recovery time against what the business needs.”

EVIDENCE TO DISCUSS

Backup scope and retention
Restore test record

NF-NCSC-MCSS-RP-01-Q1

Respond and Recover

Is there a risk-based incident response plan with named responsibilities, management support, contact paths and lessons from exercises or incidents?

WHAT THIS MEANS

A usable incident plan names the people, contact paths and first steps. Exercises or real incidents help improve it.

WHY IT MATTERS

Clear responsibilities reduce delay when an incident disrupts normal work.

EXAMPLE ANSWER: PARTIAL

“We have an incident plan and contact list. We haven’t practised it or captured lessons from an exercise.”

EVIDENCE TO DISCUSS

Incident response plan
Tabletop record

NF-NCSC-CC-PM-01-Q1

Prevent and Protect

Does the organisation provide and govern a password manager that people actually use for unique passwords and approved sharing?

WHAT THIS MEANS

The organisation provides a password manager and governs its use, including shared access and unique passwords.

WHY IT MATTERS

A managed tool makes strong passwords and controlled sharing easier to use.

EXAMPLE ANSWER: PARTIAL

“We provide a password manager. Some teams still share credentials in spreadsheets, and we haven’t checked adoption.”

EVIDENCE TO DISCUSS

User coverage
Sharing policy

NF-NCSC-CC-SV-01-Q1

Prevent and Protect

Do payment, credential, account-recovery and sensitive-data changes require a trusted verification step outside the original request?

WHAT THIS MEANS

High-impact requests need a separate check through a trusted contact path before anyone changes money, access or sensitive data.

WHY IT MATTERS

A convincing email or stolen account can make a fraudulent request look routine.

EXAMPLE ANSWER: NO

“We change supplier bank details from the reply email. We don’t verify through a number we already hold.”

EVIDENCE TO DISCUSS

Payment-change procedure
Out-of-band approval record

NF-NCSC-CC-AC-01-Q1

Prevent and Protect

Are unapproved or risky applications, scripts, macros and file types restricted on systems where they could cause material harm?

WHAT THIS MEANS

Systems limit unapproved applications, scripts, macros and risky file types where they could do harm.

WHY IT MATTERS

Controlling what can run can reduce opportunities for malicious software.

EXAMPLE ANSWER: PARTIAL

“We restrict some macros and applications. Scripts and exceptions on high-impact devices still need review.”

EVIDENCE TO DISCUSS

Endpoint policy export
Blocked application events

NF-NCSC-CC-NS-01-Q1

Detect and Contain

Are users, guests, administration, backups and important services separated so one compromise cannot freely spread?

WHAT THIS MEANS

Guest devices, everyday users, administration, backups and important services have boundaries that limit access between them.

WHY IT MATTERS

A compromised device should have fewer routes to reach other important systems.

EXAMPLE ANSWER: PARTIAL

“Guest Wi-Fi is separate. Staff devices can still reach administration and backup services more widely than necessary.”

EVIDENCE TO DISCUSS

Network and trust diagram
Segmentation test

What the results tell us

The saved result describes the answers for this scope and date.

REPORTED IMPLEMENTATION

A range reflects known answers and unresolved questions.

Completion counts show how much of the questionnaire is answered.

EVIDENCE AND JUDGEMENT

Evidence still needs review.

Risk priority and change over time need separate assessment.

An agreed action plan

We use the answers to choose work the business can own.

1	**Confirm the gap**	Resolve unknowns and check the evidence.
2	**Agree the response**	Choose an action and a business owner.
3	**Set completion criteria**	Agree a due date and evidence of completion.
4	**Review the outcome**	Check what changed before the next assessment.

About this assessment

No Fries questions adapted for New Zealand small and medium-sized organisations.

A concise implementation assessment

It does not test every Minimum Standard requirement or establish a CS-CMM level, certification, compliance or a formal risk score.

Adapted by No Fries Limited from the NCSC Cyber Security Framework and Minimum Cyber Security Standards 2025, © Crown copyright, GCSB on behalf of the Crown, licensed under CC BY 4.0. Changes were made for New Zealand SMEs. No NCSC endorsement is implied.

CC BY 4.0: https://creativecommons.org/licenses/by/4.0/

How this workshop relates to NZISM

Selected topic mapping. A starting point for further review.

WHEN IT HELPS

Government customers and suppliers may have specific assurance needs.

We confirm the actual systems, information and customer requirements.

WHAT IT PROVIDES

The appendix identifies selected references and evidence to explore.

Required assurance needs a separate, scoped control-level assessment.

Selected references only. No full NZISM assessment, compliance conclusion, accreditation or certification is provided.

NZISM v3.9, current online edition, updated November 2025. Checked 19 October 2026.

NZISM starting-point references

Questions 1–4. Selected references and gaps for further review.

Question topic	Selected references	Further checks
Q1 Risk management	5.3.7.C.01; 5.3.8.C.01 CIDs 805, 808	System-specific risk, treatment decisions and residual-risk approval still need review.
Q2 Security awareness	9.1.5.C.01–02; 9.1.6.C.01 CIDs 1452, 1453, 1457	Check required subjects, role coverage and effective behaviour beyond course completion.
Q3 Assets and importance	3.4.10.C.01; 13.1.9.C.01 CIDs 442, 3829	An inventory does not establish secure procurement, classification, handling or disposal.
Q4 Secure configuration	14.1.9.C.01 CID 1158	Detailed platform, application, cloud, network and cryptographic settings need checking.

No Fries topic mapping only. Confirm applicability and control wording in a separate assessment.

NZISM v3.9, current online edition, updated November 2025. Checked 19 October 2026.

NZISM starting-point references

Questions 5–8. Selected references and gaps for further review.

Question topic	Selected references	Further checks
Q5 Patching	12.4.4.C.02; 12.4.4.C.06 CIDs 3449, 3453	Check actual patch deadlines, coverage and mitigations against current NZISM obligations.
Q6 MFA	16.7.42.C.01–03 CIDs 7563, 6953, 7564	Check enforcement, secure recovery, exclusions and phishing-resistant MFA guidance.
Q7 Unusual behaviour	16.6.10.C.02; 23.5.12.C.01 CIDs 2013, 7498	Check retention, protected logs, time alignment, detection quality and response coverage.
Q8 Least privilege	16.4.37.C.01 16.4.38.C.01–02 CIDs 6842, 6846, 6847	Test service accounts, emergency access, revocation, monitoring and approvals.

No Fries topic mapping only. Confirm applicability and control wording in a separate assessment.

NZISM v3.9, current online edition, updated November 2025. Checked 19 October 2026.

NZISM starting-point references

Questions 9–11. Selected references and gaps for further review.

Question topic	Selected references	Further checks
Q9 Data recovery	6.4.5.C.01; 6.4.6.C.01 CIDs 1120, 1123	A sampled restore leaves whole-service recovery, dependencies and continuity untested.
Q10 Response planning	5.1.12.C.01–02 CIDs 708, 709	Reporting duties, evidence preservation, supplier coordination and response need deeper review.
Q11 Password manager	16.1.37.C.01–02 16.1.27.C.02 CIDs 7558, 7559, 7542	NZISM prohibits shared privileged credentials, with a break-glass exception. Vault use alone is insufficient.

No Fries topic mapping only. Confirm applicability and control wording in a separate assessment.

NZISM v3.9, current online edition, updated November 2025. Checked 19 October 2026.

NZISM starting-point references

Questions 12–14. Selected references and gaps for further review.

Question topic	Selected references	Further checks
Q12 Request verification	16.1.36.C.01 16.7.42.C.01–02 CIDs 1875, 7563, 6953	Identity and account recovery overlap only. These references do not cover payment changes.
Q13 Application control	14.2.4.C.01; 14.2.5.C.01 14.2.7.C.01 CIDs 1234, 1242, 934	Check default-deny, anti-tamper, administrator coverage and script or macro bypasses.
Q14 Network separation	10.8.34.C.01–02 10.8.35.C.01 CIDs 5815, 5816, 5820	Test enforced isolation, routes, identity paths, gateways and permitted traffic.

No Fries topic mapping only. Confirm applicability and control wording in a separate assessment.

NZISM v3.9, current online edition, updated November 2025. Checked 19 October 2026.